

Informe de Pentesting

1. Datos generales

- **Actividad:** A08
- **Cliente:** INSECUR S.A.
- **Laboratorio:** TryHackMe
- **Contratista (alumno/a):** Tomas Ortiz
- **DNI:** 44907961
- **Username TryHackMe:** ttomasortiz23
- **Email institucional:** ttomasortiz23@gmail.com
- **Sala de elección (Nivel 2):** kenobi
- **Branch en GitHub:** ortiz-tomas
- **Fecha de inicio:** 7 de octubre de 2026
- **Fecha de cierre:** 9 de octubre de 2026

2. Pre-pentesting

Alcance del trabajo

El alcance autorizado comprende exclusivamente la máquina virtual asignada por la plataforma TryHackMe para la sala "Kenobi" (Nivel 2), identificada durante las sesiones de trabajo por la dirección IP 10.65.143.103. Queda fuera de alcance cualquier otro sistema, red o servicio no provisto explícitamente por TryHackMe para esta actividad.

Reglas de Enfrentamiento (ROE)

Las pruebas se realizaron únicamente dentro del entorno aislado (sandbox) de TryHackMe, sin horarios restringidos. No se utilizaron técnicas destructivas (sin borrado de archivos del sistema objetivo ni modificación irrecuperable de configuraciones). Los escaneos de puertos y pruebas de enumeración se realizaron con un número de hilos moderado para no perturbar la estabilidad del servicio del laboratorio.

Autorización

Se declara que se cuenta con autorización expresa de la cátedra "Seguridad Aplicada a Sistemas de Información" (UCH) para operar sobre el entorno de TryHackMe indicado para la sala Kenobi, conforme a la guía de la Actividad A08 y la Carta de Autorización correspondiente.

Metodología utilizada

Se siguió el flujo profesional de pentesting propuesto por la cátedra (Preengagement, Reconocimiento, Escaneo, Enumeración, Explotación, Postexplotación, Reporte), alineado conceptualmente con las fases de PTES (*Penetration Testing Execution Standard*).

3. Durante: Hallazgos por fase

H-01: Exposición de recursos compartidos SMB sin autenticación

- **Fase:** Reconocimiento / Enumeración
- **Descripción:** El servidor Samba expone el recurso compartido llamado `anonymous` accesible sin credenciales (sesión nula). Dentro de este recurso se encontró el archivo `log.txt` con información sensible sobre la configuración interna del sistema, rutas de claves privadas y comandos ejecutados por el administrador.
- **Componente afectado:** Servicio Samba / SMB (puertos 139/445)
- **Categoría (OWASP/CWE):** CWE-284 (Control de acceso incorrecto) / OWASP A01:2021-Broken Access Control
- **CVE (si aplica):** No aplica (error de configuración)
- **CVSS estimado:** Medio (5.3)
- **Evidencia:** evidencias/escaneo/escaneo_kenobi.png (comando: `smbclient -L //10.65.143.103/ -N`)
- **Herramienta utilizada:** `smbclient`, `nmap`
- **Impacto en la Tríada CIA:** Confidencialidad
- **Salvaguarda propuesta:** Deshabilitar el acceso anónimo a recursos compartidos en Samba ajustando las políticas en `smb.conf` (`map to guest = bad user restringido`) y exigir autenticación previa.
- **Riesgo residual tras aplicar:** Bajo

H-02: Recurso NFS compartido sin restricción de montaje remoto

- **Fase:** Enumeración
- **Descripción:** El servicio Network File System (NFS) expone el punto de montaje `/var` accesible libremente. Esto permite que cualquier atacante en la red monte el sistema de archivos `/var` localmente y acceda o altere los archivos alojados en dicho directorio.
- **Componente afectado:** Servicio NFS / RPCbind (puertos 111/2049)
- **Categoría (OWASP/CWE):** CWE-276 (Permisos por defecto incorrectos) / OWASP A05:2021-Security Misconfiguration
- **CVE (si aplica):** No aplica
- **CVSS estimado:** Alto (7.5)
- **Evidencia:** evidencias/explotacion/explotacion_kenobi.png (comando: `showmount -e 10.65.143.103`)
- **Herramienta utilizada:** `showmount`, `mount`
- **Impacto en la Tríada CIA:** Confidencialidad, Integridad
- **Salvaguarda propuesta:** Restringir en el archivo `/etc/exports` las direcciones IP autorizadas a montar carpetas y configurar parámetros de restricción como `root_squash`.
- **Riesgo residual tras aplicar:** Bajo

H-03: Copia remota no autenticada de archivos en ProFTPD (mod_copy)

- **Fase:** Explotación
- **Descripción:** El servidor FTP ProFTPD 1.3.5 posee activado el módulo `mod_copy`, el cual permite utilizar los comandos no autenticados `SITE CPER` y `SITE CPTO` para copiar archivos del sistema hacia cualquier ruta. Se explotó esta vulnerabilidad para copiar la clave SSH privada del usuario `kenobi` (`/home/kenobi/.ssh/id_rsa`) al directorio temporal `/var/tmp/id_rsa`.

- **Componente afectado:** Servicio FTP (ProFTPD 1.3.5, puerto 21)
- **Categoría (OWASP/CWE):** CWE-284 (Control de acceso incorrecto) / OWASP A06:2021-Vulnerable and Outdated Components
- **CVE (si aplica):** CVE-2015-3306
- **CVSS estimado:** Crítico (9.8)
- **Evidencia:** bitacora/kenobi.txt (comandos `SITE CPFR /home/kenobi/.ssh/id_rsa` y `SITE CPTO /var/tmp/id_rsa` mediante netcat)
- **Herramienta utilizada:** netcat, nmap
- **Impacto en la Tríada CIA:** Confidencialidad, Integridad, Disponibilidad
- **Salvaguarda propuesta:** Actualizar el servicio ProFTPD a una versión reciente o deshabilitar el módulo `mod_copy` en la configuración del servicio.
- **Riesgo residual tras aplicar:** Bajo

H-04: Exfiltración de clave privada SSH mediante montaje de NFS

- **Fase:** Explotación
- **Descripción:** Al combinar la copia de la llave SSH (`id_rsa`) en `/var/tmp` mediante la vulnerabilidad de ProFTPD con la exportación NFS del directorio `/var`, se montó la carpeta NFS en la máquina atacante para copiar la clave `id_rsa`, permitiendo iniciar sesión SSH directa como el usuario `kenobi`.
- **Componente afectado:** Servicio SSH (puerto 22), cuenta `kenobi`
- **Categoría (OWASP/CWE):** CWE-552 (Archivos accesibles a usuarios no autorizados)
- **CVE (si aplica):** No aplica
- **CVSS estimado:** Alto (8.1)
- **Evidencia:** evidencias/explotacion/explotacion_kenobi.png (conexión exitosa `ssh -i kenobi_id_rsa kenobi@10.65.143.103`)
- **Herramienta utilizada:** mount, ssh
- **Impacto en la Tríada CIA:** Confidencialidad, Integridad
- **Salvaguarda propuesta:** Proteger las llaves privadas SSH mediante passphrases robustas y restringir los permisos y rutas expuestas por el servicio NFS.
- **Riesgo residual tras aplicar:** Bajo

H-05: Invocación no segura en binario SUID (PATH Hijacking y Escalada a Root)

- **Fase:** Postexplotación / Escalada de Privilegios
- **Descripción:** El binario personalizado `/usr/bin/menu` posee el bit SUID activo y pertenece al usuario `root`. El análisis del binario con la herramienta `strings` reveló que ejecuta la utilidad `curl` sin especificar la ruta absoluta (`curl -I localhost`). Modificando la variable de entorno `PATH` (`export PATH=/tmp:$PATH`) y creando un ejecutable malicioso en `/tmp/curl` que lanza `/bin/sh`, se consiguió ejecutar comandos como superusuario al seleccionar la opción 1 del menú.
- **Componente afectado:** Binario `/usr/bin/menu`, variable de entorno `PATH`, cuenta `root`
- **Categoría (OWASP/CWE):** CWE-426 (Búsqueda por ruta no confiable) / OWASP A04:2021-Insecure Design
- **CVE (si aplica):** No aplica
- **CVSS estimado:** Crítico (9.8)

- **Evidencia:** evidencias/post/post_kenobi.png (Obtención de shell root y flag: 177b3cd8562289f37382721c28381f02)
- **Herramienta utilizada:** find, strings, export, /usr/bin/menu
- **Impacto en la Tríada CIA:** Confidencialidad, Integridad, Disponibilidad
- **Salvaguarda propuesta:** Eliminar el bit SUID innecesario del binario /usr/bin/menu. En código fuente, especificar siempre rutas absolutas para cualquier comando del sistema (por ejemplo, /usr/bin/curl).
- **Riesgo residual tras aplicar:** Bajo

4. Resumen ejecutivo de hallazgos

- **Crítico:** 2 (H-03, H-05)
- **Alto:** 2 (H-02, H-04)
- **Medio:** 1 (H-01)
- **Bajo:** 0
- **Total:** 5 hallazgos (H-01 a H-05)

La cadena de explotación completa (enumeración de SMB/NFS → explotación del módulo ProFTPD `mod_copy` → extracción de clave SSH vía NFS → pivoteo a SSH → escalada de privilegios a root por *PATH hijacking* sobre binario SUID) demuestra cómo fallas de configuración y vulnerabilidades en software desactualizado pueden encadenarse para lograr el control absoluto del servidor objetivo.

5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

1. Deshabilitar el acceso anónimo al recurso SMB `anonymous` y exigir autenticación obligatoria.
2. Restringir en el archivo `/etc/exports` las IPs que pueden montar recursos NFS y retirar el directorio `/var` de las exportaciones.
3. Actualizar ProFTPD a una versión sin la vulnerabilidad CVE-2015-3306 o desactivar el módulo `mod_copy`.
4. Retirar el permiso SUID del ejecutable `/usr/bin/menu` o corregir su código fuente utilizando rutas absolutas (`/usr/bin/curl`).
5. Asegurar que las claves privadas SSH estén protegidas por contraseñas/passphrases y restringir sus permisos a `600`.

Recomendaciones administrativas (políticas y procesos)

1. Implementar auditorías periódicas automatizadas de archivos con bits SUID/SGID.
2. Definir una política de gestión de parches para los servicios expuestos a la red (FTP, NFS, Samba, SSH).
3. Establecer guías de desarrollo seguro para la creación de scripts y herramientas internas que interactúan con el sistema operativo.

6. Protocolo de Contingencia

Escenario de falla

Un atacante externo replica la cadena observada: explota ProFTPD para mover archivos, extrae la clave SSH usando NFS y escala a superusuario mediante la manipulación de binarios SUID, obteniendo control total del servidor de producción de INSECUR S.A.

Impacto sobre la continuidad del negocio

El compromiso total del superusuario `root` afectaría la confidencialidad de los datos almacenados, la integridad de los registros del sistema y la disponibilidad de los servicios en producción, con un tiempo de interrupción estimado hasta la contención y remediación.

Plan de respuesta

1. **Activación:** Detección de patrones anómalos de comandos FTP (`SITE CPFR/SITE CPTO`), conexiones SSH inusuales o procesos raíz no autorizados.
2. **Contención:** Aislar el servidor afectado de la red local, cerrar las sesiones activas y suspender las cuentas comprometidas.
3. **Recuperación:** Restaurar el servidor a un estado seguro desde una copia de respaldo limpia, actualizar ProFTPD y aplicar correcciones a los binarios SUID.
4. **Comunicación:** Informar a la Dirección de TI y a los responsables de seguridad de la empresa según el procedimiento de incidentes.
5. **Post-mortem:** Documentar la causa raíz y actualizar los controles de endurecimiento (*hardening*).

RTO y RPO estimados

- **RTO:** 4 horas (tiempo para aislar el host, verificar integridad y restaurar desde una imagen limpia).
- **RPO:** 24 horas (asumiendo esquemas de respaldo diarios automáticos).

7. Anexos

Anexo A: Bitácora de comandos

Ver el archivo `bitacora/kenobi.txt` en el repositorio de la materia, con el registro cronológico completo de todos los comandos ejecutados.

Anexo B: Capturas de pantalla y evidencias

Ver las evidencias organizadas en el repositorio dentro de la estructura de subcarpetas: `evidencias/escaneo/`, `evidencias/explotacion/` y `evidencias/post/`.

Anexo C: Hashes de las flags obtenidas

- **Flag Root:** `177b3cd8562289f37382721c28381f02`

- **SHA-256:**
e8db3133e387c96d74f2603dc69d4d42b8e39adbf47225c56d7dfd1ddbe6cbb6
(generado con `echo -n "177b3cd8562289f37382721c28381f02" | sha256sum`)

Anexo D: Declaración ética firmada

Declaro que todas las actividades documentadas en este informe se realizaron dentro del alcance autorizado, en entornos controlados de TryHackMe y con fines exclusivamente académicos.